WAGESSE

Contrôles de sécurité — préproduction

Date : 7 novembre 2026, 19:50 (Europe/Paris). Cible : https://preprod.wagesse.fr. Aucun test destructif sur les autres applications du VPS.

Résultats exécutés

Contrôle	Résultat
Inscription avec le rôle ADMIN	Refusée, HTTP 400
Mot de passe incorrect	HTTP 401, message générique
Tableau de bord admin sans jeton	HTTP 401
Tableau de bord admin avec un client	HTTP 401, aucune donnée
Liste des utilisateurs avec un transporteur	HTTP 401
Demande d'un autre client	HTTP 403
Refus d'un devis d'un autre client	HTTP 403
Véhicules d'un autre transporteur	absents de la liste
Devis du client	deux devis, numéros de transporteurs absents du JSON
Second devis du même transporteur	HTTP 400
Achat, forfait et déblocage sans téléphone vérifié	HTTP 403, solde resté à 0
Webhook PayDunya forgé	HTTP 403, PayDunya désactivé
Mot de passe oublié	réponse sans code, SMS non délivré
Code de réinitialisation faux	HTTP 400, l'ancien mot de passe fonctionne encore
Page /admin ouverte par un transporteur	tableau de bord transporteur, pas l'administration

Limites

Dans la branche, la vérification JWT n'accepte que HS256. Les en-têtes HSTS, nosniff, DENY, Referrer-Policy et Permissions-Policy sont déclarés, et X-Powered-By est retiré. axios est retiré. zod est en 4.6.7. Une route d'administration peut marquer un compte fictif comme vérifié, seulement si le drapeau de préproduction est exactement true, et sans renvoyer de code.

Le compte administrateur initial n'a pas été utilisé. Les doubles validations de paiement n'ont pas été rejouées. Les en-têtes ne sont pas encore servis par le site. L'alerte critique Next.js reste et vise Windows. Firefox et Safari n'ont pas été ouverts.